

UNCLASSIFIED



APPLE MACOS 12 (MONTEREY) SUPPLEMENTAL DOCUMENT

Version 1, Release 9

24 July 2024

Developed by Apple and DISA for the DOD

UNCLASSIFIED

Trademark Information

Names, products, and services referenced within this document may be the trade names, trademarks, or service marks of their respective owners. References to commercial vendors and their products or services are provided strictly as a convenience to our users, and do not constitute or imply endorsement by the Defense Information Systems Agency (DISA) of any nonfederal entity, event, product, service, or enterprise.

TABLE OF CONTENTS

	Page
1. TECHNOLOGY IMPLEMENTATION CONSIDERATIONS.....	1
1.1 FIPS 140-3 Validation	1
2. TECHNOLOGY FEATURES.....	2
2.1 Malware Protection	2
2.2 Software Updates	2
2.3 Data-at-Rest Protection.....	2
2.4 Device Deployment and Management.....	2
2.4.1 Use of Apple Products on Enterprise Networks	2
2.4.2 Apple Push Notification Service (APNs)	3
2.4.3 Configuration Profiles.....	3
2.4.4 Mobile Device Management (MDM)	3
2.5 Firmware Password	3
2.6 Smart Cards.....	4
2.7 Domain Binding.....	4
2.8 Kernel Extensions	5
2.8.1 Endpoint Security Framework	5
3. SUPPLEMENTAL PROCEDURES.....	6
3.1 Building a Certificate Root Trust Payload	6
3.2 macOS Hard Disk Erase Procedures	6
3.3 Example Setup Workflow.....	7

1. TECHNOLOGY IMPLEMENTATION CONSIDERATIONS

1.1 FIPS 140-3 Validation

Some of the cryptographic modules supporting Apple macOS 12 have not been FIPS 140-3 validated as of the date of this publication but are in process. DOD organizations using macOS 12 devices should visit the following website to obtain updates on validation status:

<https://support.apple.com/guide/sccc/security-certifications-for-macos-sccc5eb3dc4fa/web>

The cryptographic modules supporting Apple macOS 12 are being revalidated to accommodate new features in Apple macOS 12. The previously validated cryptographic modules are:

- Apple CoreCrypto Module for Intel (ccv10) – A software cryptographic module running on a multi-chip standalone hardware device that provides services intended to protect data in transit and at rest. (FIPS Certificate number 3859).
- Apple CoreCrypto Kernel Module for Intel (ccv10) – Used by the kernel for low-level services intended to protect data in transit and at rest. (FIPS Certificate number 3858).
- Apple Secure Key Store Cryptographic Module, (ccv10) – Provides services intended to protect data in transit and at rest on T2 equipped Macs. (FIPS Certificate number 3811).

2. TECHNOLOGY FEATURES

2.1 Malware Protection

macOS includes built-in protections against malware. Gatekeeper ensures that by default, only trusted software runs on the system. XProtect is a built-in, signature-based antivirus tool that helps protect macOS from malware infections. XProtect definition files are updated by Apple automatically, independent of OS updates. Malware Removal Tool is an engine used to remediate infections should one find its way onto the system. The Malware Removal Tool is updated by Apple on systems configured to receive automatic security updates. More information about these built-in tools can be found at the following links:

<https://support.apple.com/guide/security/gatekeeper-and-runtime-protection-sec5599b66df/web>
<https://support.apple.com/guide/security/protecting-against-malware-sec469d47bd8/>

2.2 Software Updates

Keeping macOS up to date ensures it has the latest enhancements and security controls in place. This STIG requires that all updates come from an approved source. Apple is considered a DOD-approved source. Apple-provided updates must be installed on Apple macOS devices when available. Apple provides the capability for DOD support staff to test most updates before they are released.

Apple provides system administrators with the ability to manage macOS updates through mobile device management. <https://support.apple.com/en-us/HT211951>

2.3 Data-at-Rest Protection

macOS does not support unlocking FileVault encrypted volumes using smart card-based authentication on Intel-based systems. Therefore, the use of a dedicated local FDE unlock user is required. The unlock user is a password-based account that can only be used to unlock the FileVault encrypted volume. The "unlock" account cannot be used to log in to the operating system. Authorized users boot their systems, enter a password at the pre-boot screen that decrypts the boot volume, and when presented with the login window, authenticate using a smart card. Refer to this link for more information: <https://support.apple.com/guide/security/when-filevault-is-turned-on-sec4c6dc1b6e/web>

macOS, when running on Apple Silicon-based systems, transparently supports decrypting the FileVault volume for any user who is configured to use a smart card and whose account is authorized to do so. <https://support.apple.com/guide/security/managing-filevault-sec8447f5049/1/web/1>

2.4 Device Deployment and Management

2.4.1 Use of Apple Products on Enterprise Networks

Automated deployment and management of Apple devices may require access to specific network services. Apple publishes detailed information about which hosts and ports are required to use

Apple products on enterprise networks at the following link: <https://support.apple.com/en-us/HT210060>

Configuration of a network using this information is approved for DOD use. If the firewall supports using hostnames, the Apple services above can be used by allowing outbound connections to *.apple.com. If the firewall can only be configured with IP addresses, allow outbound connections to 17.0.0.0/8. The entire 17.0.0.0/8 address block is assigned to Apple.

2.4.2 Apple Push Notification Service (APNs)

APNs is a platform notification system that developers use to send notification alerts to devices manufactured by Apple, Inc. In addition to app-based alerts, APNs is used by Mobile Device Management (MDM) servers to manage enrolled devices.

APNs is an encrypted and authenticated communication protocol approved for DOD use.

2.4.3 Configuration Profiles

A configuration profile is an XML file that applies configuration information to macOS devices. Settings defined by an installed configuration profile cannot be changed by the user. In some cases, a user can opt to make a setting more restrictive than what is defined in the profile. For example, if a configuration profile requires the device to lock after five minutes, the user can set the device to lock immediately.

Configuration Profiles can be installed manually or with the use of an MDM server. To install profiles manually, copy them to the target machine, double-click on the profile(s), open System Preferences/Profiles, and click "Install" for each of the profiles to be installed. For more information, refer to: <https://support.apple.com/guide/deployment-reference-macos/welcome/web>

2.4.4 Mobile Device Management (MDM)

MDM servers enable the remote management of enrolled systems. Management includes configuring restrictions, deploying credentials, monitoring compliance, or remotely wiping or locking devices. Using MDM servers to manage macOS devices is a best practice and enables some capabilities that are not possible via other means, such as enabling the Recovery Partition password on Apple Silicon based systems and preventing local users from installing Kernel Extensions. <https://support.apple.com/guide/mdm/mdm-overview-mdmbf9e668/web>

2.5 Firmware Password

Intel-based macOS systems include a recovery partition which can be used to reinstall the operating system, reset local user passwords, and partition the disk, among other tasks. Setting a firmware password on the system will restrict access to the recovery partition and prevent the user from

booting the computer from external media or from booting into Target Disk Mode. Refer to: <https://support.apple.com/en-us/HT201462>

The firmware password (<https://support.apple.com/en-us/HT204455>) can be set or removed from the recovery partition using either the Firmware Password Utility or Startup Security Utility. The firmware password can also be set, removed, or verified while logged in to macOS using the `firmwarepasswd` command. Once a firmware password is set, macOS will ask for the firmware password when attempting to boot from a volume other than the one set in the Startup Disk preference pane, or when starting up into the Recovery partition.

Note: The only way to reset a forgotten password is with a machine-specific binary generated and provided by Apple. A user will need to schedule a support call and provide proof of purchase before the firmware binary will be generated.

On Apple Silicon-based systems, starting in macOS 11.5, MDM administrators can set (using the new `SetRecoveryLock` command) a password that must be entered before a user can restart the system with Apple Silicon into the recoveryOS. For example, the user will not be able to modify security settings or erase the system. This password can be set only by the MDM solution; it can be removed by the MDM solution, unenrolling in MDM, or if the system is erased. MDM administrators can also verify a recoveryOS password is set by using the new `VerifyRecoveryLock` command.

2.6 Smart Cards

macOS supports Personal Identity Verification (PIV)-based smart cards and has built-in support for USB CCID class-compliant smart card readers. Smart card-based authentication is supported in the following subsystems: Login Window, Screen Saver, `ssh`, `sudo`, Safari, PAM Authorization, `login`, `su`, and Finder.

Smart card-based authentication on macOS can be configured in fixed-key mapping or attribute-based mapping. Fixed-key mapping associates the hash of a public key on the users' smart card with a local account. Attribute-based matching associates certificate field values from the smart card to predefined values in a Directory Server.

By default, macOS will authenticate users using either a password or a smart card that has been bound to their account through fixed key or attribute mapping. Mandatory smart card-based authentication can be enabled using a configuration profile. Enabling mandatory smart card-based authentication without first verifying that smart card authentication is working can prevent all users from logging into the machine. For more information, refer to: <https://support.apple.com/en-us/HT208372>

2.7 Domain Binding

Binding macOS to Active Directory is used to enforce Password Complexity settings that the operating system itself does not support. If mandatory smart card-based authentication is enforced, the Active Directory Binding requirement is not applicable. Active Directory binding is supported with domains running at a functional level of Windows 2000 or later. Note that when binding to pre-2008 domains, "weak crypto" must be enabled and is therefore not recommended.

macOS will use Active Directory authentication policies, including password changes, expirations, forced changes, and security options, with no schema changes required. macOS will not use another Group Policy from Active Directory.

For more information, refer to: <https://support.apple.com/guide/deployment-reference-macos/single-sign-on-extension-apdac83c038d/web>

2.8 Kernel Extensions

Kernel Extensions (Kexts) are no longer recommended for macOS. The use of Kexts puts the performance and reliability of the system at risk. Systems administrators should select solutions that do not require extending the kernel. See <https://support.apple.com/guide/security/kernel-extensions-sec8e454101b/1/web/1>

2.8.1 Endpoint Security Framework

Starting in macOS 10.15 (Catalina), all version of macOS include an Endpoint Security Framework that provides a C-Language API which can be used to monitor the system for malicious activity. The events which can be monitored include process executions, mounting file systems, forking processes, and raising signals.

<https://developer.apple.com/documentation/endpointsecurity>

3. SUPPLEMENTAL PROCEDURES

3.1 Building a Certificate Root Trust Payload

Logging in to a macOS machine that has had a STIG applied requires identities on the CACs used to authenticate users be trusted. Apple has not shipped DOD roots in the trust store for macOS since High Sierra. The following steps demonstrate how to build a Configuration Profile that contains the current DOD roots required to establish trust.

The root certificates are available from the DISA PKI Page: <https://cyber.mil/pki-pke/tools-configuration-files/>

Alternatively, use the direct download link: https://dl.cyber.mil/pki-pke/zip/unclass-Certificates_PKCS7_v5.5_ECA.zip

After downloading and expanding the ZIP, follow the instructions in the README.txt to verify the certificates. Use the following command to convert the archive to PEM for use in the next step:

```
openssl pkcs7 -in Certificates_PKCS7_v5.5_DOD.pem.p7b -print_certs -out  
DOD_CAs.pem
```

Convert the PEM encoded file to p12.

```
openssl pkcs12 -export -nokeys -in DOD_CAs.pem -out DOD_CAs.p12
```

Once the P12 has been created, create a new Configuration Profile and import the newly created p12 into that Profile as a certificate payload. For more information, refer to: <https://support.apple.com/guide/apple-configurator-2/create-and-edit-configuration-profiles-pmd85719196/mac>

This will produce a mobileconfig policy file that applies only to users who install the file. To make this a system policy, open the mobileconfig file with a text editor and insert the following two lines before the closing dict and plist at the end of the file "</dict></plist>":

```
<key>PayloadScope</key>  
<string>System</string>
```

3.2 macOS Hard Disk Erase Procedures

A cryptographic wipe is designed to permanently delete data so it cannot be recovered; this includes email accounts, downloaded apps, media files, documents, browser bookmarks, and settings. These procedures are appropriate for macOS devices never exposed to classified data and require that FileVault Disk Encryption is enabled.

Follow the steps below when any macOS system is being retired from use:

1. Boot from the Recovery partition.
2. Select "Disk Utility" from the macOS Utilities window and click "Continue".
3. Select the Hard Disk to be erased, click "Erase", and fill in the requested fields shown below:
 - Name: Type the name the disk will have after it is erased.

- Format: Choose "APFS" or "Mac OS Extended (Journaled)"; Disk Utility shows a compatible format by default.
- Scheme: Choose "GUID Partition Map".

For more information, refer to: <https://support.apple.com/en-us/HT208496> and <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>

Apple Silicon or Intel-based systems with a T2 Security Chip running macOS 12 will allow a local administrator, or MDM administrator if the system is enrolled, to perform an Erase All Content and Settings. This command erases all user data and any additional volumes on the system. On Apple Silicon based systems, the system's security settings are reset to their default value, Full Security.

3.3 Example Setup Workflow

macOS ships in a least-privilege configuration. The first user configured during initial setup will be an administrative user. The accepted best practice is for all subsequent users to be non-privileged users. Some user tasks may require elevated permissions. In these cases, system administrators should configure the system to support the constrained ability of users to accomplish required tasks. The built-in command-line tools "sudo" and "security" can be used to grant additional permissions to unprivileged users. See "man sudo" and the authorizationdb section of "man security" for more information.

The following workflow addresses only the simplest use case of setting up a standalone or networked machine using mandatory smart card authentication against a local account. More complicated workflows, including directory-bound or Apple Business Manager (ABM)-based enrollments, are beyond the scope of this section. The following procedure will provision a local admin account, which will be exempt from the smart card mandatory policy, and a local unprivileged user account, which is bound by the smart card mandatory policy. Using this method will verify that the certificates required to establish trust are in place and the mandatory smart card policy is in place without risking locking the local administrator account. Once smart card login is verified as working, consider removing the smart card mandatory exemption for the administrative user.

1. Collect required equipment.
 - System running 10.11.x or greater.
 - STIG materials.
 - Smart card that will be paired with the local administrator account.
 - USB smart card reader.
 - Certificates required to establish smart card trust.
2. Power on the system and proceed through the setup assistant.
3. At the "Create a Computer Account" prompt:
 - This account will be the local administrative account of last resort.
 - The name of the account should follow local conventions.
 - **Note:** When setting up this user, steps will be displayed that will be suppressed for users that are created after applying the STIG.

4. Install the certificate roots and intermediates, which are required to validate the trust chain used for the organization's smart cards.
5. Insert administrative smart card and follow the on-screen prompts to pair with the local account. Keyboard Setup prompts may be dismissed safely.
 - The onscreen prompts require creating a password, which will be wrapped with the private key from the smart card to secure the users' macOS keychain.
 - Verify the pairing by logging out and then back in, using the smart card to authenticate.
6. Create a new unprivileged user, sign in as that user, and associate a smart card to the user's account.
7. Log in as the administrative user.
8. Apply the, U_Apple_macOS_12_V1R1_STIG_Test_Smart_Card_Mandatory, configuration profile, which will enforce mandatory certificate checks.
9. Log in as the administrative user using the smart card.
 - If unable to log in as the administrator using the smart card, log in using the password and correct the certificate trust problem.
10. Apply the U_Apple_macOS_12_V1R1_STIG_Smart_Card_Policy, configuration profile, which enforces mandatory smart card logins. This profile will override and replace the Test Smart Card Mandatory profile from step 8.
11. Verify that the unprivileged user cannot log in with a password and must use the smart card.